EXPOSURE OF INFORMATIONS USING CROSS-SITE SCRIPTING

DESCRIPTION

Cross-site scripting (XSS) allows an attacker to inject malicious executable scripts into a trusted application website, giving them access to retrieve sensitive information or view unauthorized pages.

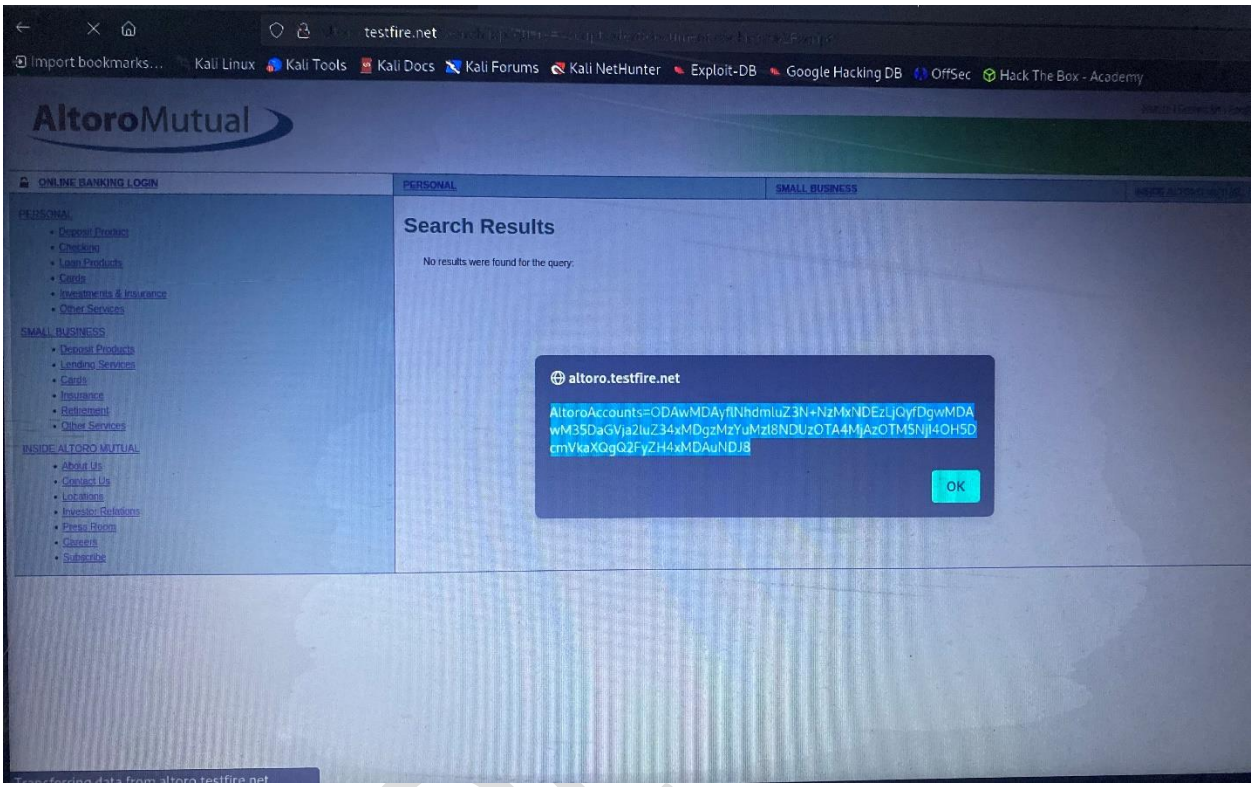
URL: https://demo.testfire.net/login.jsp

STEPS TO REPRODUCE:

- Navigate to: https://demo.testfire.net/login.jsp
- On the search box run the script, <script>alert(document.cookie)</script>
- The application will display an information encoded in base64, go ahead and decode it with any decoder of your choice.
- The decoded information displays various Altoro mutual account information, including co-operate checking and saving accounts, with the account balances and credit card details.

CONFIDENTIAL

I



IMPACT:

- This is exposure of sensitive information, which an attacker can leverage to commit fraud, identity theft and financial loss for the users and Altoro bank.
- Reputational damage
- Payment of fines to the government

MITIGATION:

- Filter input on arrival. At the point where user input is received, filter as strictly as possible based on what is expected or valid input. Encode data on output.
- Use a Content Security Policy (CSP) that allows you to specify which sources of content are allowed to be loaded on your webpage. This can help prevent XSS attacks by preventing malicious code from being loaded from untrusted sources.
- This code below sets the Content-Security-Policy header to only allow content from the same domain as the webpage. It also specifies that scripts can only be loaded from a trusted source.

```
// Set the Content Security Policy header
app.use(function (req, res, next) {
  ('Content-Security-Policy, "default-src 'self' ");
  next();
});

// Load scripts only from trusted sources
<script src="[https://trusted-
site.com/script.js](https://trusted-
site.com/script.js)"></script>
der
app.use(function (req, res, next) {
  res.setHeader('Content-Security-Policy, "default-src
'self' ");
  next();
});

// Load scripts only from trusted sources
<script src="[https://trusted-
site.com/script.js](https://trusted-
site.com/script.js)"></script>
```

HTTP REQUEST PARAMETER TAMPERING

DESCRIPTION

This is a type of IDOR vulnerability that allows users to modify or change an identifier from the request sent over the application, hence being able to intercept and modify transactions or information.

URL: https://demo.testfire.net/bank/transfer.jsp

URL: https://demo.testfire.net/feedback.jsp

STEPS TO REPRODUCE:

- Navigate to : https://demo.testfire.net/bank/transfer.jsp and https://demo.testfire.net/feedback.jsp
- First try to transfer any amount from your account to another's
- Turn on intercept on Burpsuite before confirming the transaction.
- On the Burpsuite navigate to the HTTP GET request and change the amount of money transferred to any amount of your choice, also change the account number to the unintended account number.
- Forward the request and go back to the Altoro banking application, check the recent transaction
- You have successfully transferred money to an entirely different account without the user knowing.
- You can also intercept the feedback requests and change an authenticated email address to yours and the bank can unknowingly send sensitive information like credit card and account information to your email that you are not supposed to access.

Burp Suite Community Edition v2023.12.1.3 - Temporary Project

Burp Project Intruder Repeater View Help

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

1 × 2 × 3 ×

Send Cancel

Target: ht

Request

Pretty Raw Hex

```
1  POST /sendFeedback HTTP/1.1
2  Host: altoromutual.com:8080
3  Content-Length: 122
4  Cache-Control: max-age=0
5  Upgrade-Insecure-Requests: 1
6  Origin: http://altoromutual.com:8080
7  Content-Type: application/x-www-form-urlencoded
8  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
   Gecko) Chrome/121.0.6167.85 Safari/537.36
9  Accept:
   text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*
   /*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Referer: http://altoromutual.com:8080/feedback.jsp
11 Accept-Encoding: gzip, deflate, br
12 Accept-Language: en-US,en;q=0.9
13 Cookie: JSESSIONID=7C5A638D51EF4DDA78E72FFB90E1DFB9; AltoroAccounts=
   "ODAwMDAyflNhdmluZ3N+MTAwMDUuNDJ8ODAwMDAzfkNoZWNraW5nfjEQOTk5LjM5fDQ1MzkwODIwMzkzOTYyODh
   +03JL2G1OIENhcmR+MTA5LjkyfA==”
14 Connection: close
15
16 cfile=comments.txt&name=John+Smith&email_addr=test@yahoo.com&subject=credit+card&
   comments=creditcardnumber&submit=+Submit+
```

Response

Pretty Raw Hex Render

```
103          <!-- TOC END -->
104
105          <td valign="top" colspan="3" class="bb">
106
107
108
109            <div class="fl" style="width: 99%;">
110
111              <h1>
                   Thank You
                 </h1>
112
113              <p>
                   Thank you for your comments, John Smith.  They will be reviewed by our
                   Customer Service staff and given the full attention that they deserve.
114
115                Our reply will be sent to your email: test@yahoo.com
116
117              </p>
118
119            </div>
120          </td>
121        </div>
122
123
124
125        <!-- BEGIN FOOTER -->
126
127
128      </tr>
129    </table>
130    <div id="footer" style="width: 99%;">
131      <a id="HyperLink5" href="/index.jsp?content=privacy.htm">
         Privacy Policy
       </a>
132      |  
133    <a id="HyperLink6" href="/index.jsp?content=security.htm">
         Security Statement
       </a>
134      |  
```

Search 0 highlights

Search 0 highlights

Done

Event log All issues

Burp Suite Community Edition v2023.12.1.3 - Temporary Project

Target: http://altoromutual.com:8080

Request

```
POST /sendFeedback HTTP/1.1
Host: altoromutual.com:8080
Content-Length: 150
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
Origin: http://altoromutual.com:8080
Content-Type: application/x-www-form-urlencoded
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/121.0.6167.85 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,applicat
ion/signed-exchange;v=b3;q=0.7
Referer: http://altoromutual.com:8080/feedback.jsp
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9
Cookie: JSESSIONID=7C5A638D51EF4DDA78E72FF890E1DF89; AltoroAccounts=
"ODAwMDAyflNhdnluZ3N+MTAwMDUuNDJBODAwMDAzfkNoZWNraWSnfjEOOTk5LjM5fDQ1MzkwODIwMzkzOTYyODh+03JlZGl0IENhcmR-
MTA5LjkyfA=="
Connection: close

cfile=comments.txt&name=John+Smith&email_addr=johnsmith%40yahoo.com&subject=credit+card+information&
comments=please+send+my+card+numer&submit=+Submit+
```

Response

```
                <a id="MenuHyperLink18" href="index.jsp?content=inside_careers.htm">
                  Careers
                </a>
              </li>
              <li>
                <a id="MenuHyperLink19" href="Subscribe.jsp">
                  Subscribe
                </a>
              </li>
            </ul>
          </td>
          <!-- TOC END -->

          <td valign="top" colspan="3" class="bb">


            <div class="fl" style="width: 99%;">

              <h1>
                Thank You
              </h1>

              <p>
                Thank you for your comments, John Smith.  They will be reviewed by our Customer Service
                staff and given the full attention that they deserve.

                Our reply will be sent to your email: johnsmith@yahoo.com

              </p>

            </div>
          </td>

        </div>


        <!-- BEGIN FOOTER -->
```

CONFI

Burp Suite Community Edition v2023.12.1.3 - Temporary Project

Burp Project Intruder Repeater View Help

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

1 × 2 × 3 × +

Send Cancel < | > | Target: ht

Request

Pretty Raw Hex

```
1 POST /sendFeedback HTTP/1.1
2 Host: altoromutual.com:8080
3 Content-Length: 122
4 Cache-Control: max-age=0
5 Upgrade-Insecure-Requests: 1
6 Origin: http://altoromutual.com:8080
7 Content-Type: application/x-www-form-urlencoded
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
  Gecko) Chrome/121.0.6167.85 Safari/537.36
9 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*
  /*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Referer: http://altoromutual.com:8080/feedback.jsp
11 Accept-Encoding: gzip, deflate, br
12 Accept-Language: en-US,en;q=0.9
13 Cookie: JSESSIONID=7C5A638D51EF4DDA78E72FFB90E1DFB9; AltoroAccounts=
   "ODAwMDAyflNhdmluZ3N+MTAwMDUuNDI8ODAwMDAzfkNoZWNraWSmfjE0OTk5LjM5fDQ1MzkwODIwMzkzOTYyODh
   +O3JlZGlOIENhcmR+MTA5LjkyfA==”
14 Connection: close
15
16 cfile=comments.txt&name=John+Smith&email_addr=test@yahoo.com&subject=credit+card&
   comments=creditcardnumber&submit=+Submit+
```

Response

Pretty Raw Hex Render

```
103         <!-- TOC END -->
104
105         <td valign="top" colspan="3" class="bb">
106
107
108
109           <div class="fl" style="width: 99%;">
110
111             <h1>
                  Thank You
                </h1>
112
113             <p>
                  Thank you for your comments, John Smith.  They will be reviewed by our
                  Customer Service staff and given the full attention that they deserve.
114
                  Our reply will be sent to your email: test@yahoo.com
115
116
117             </p>
118
119           </div>
120         </td>
121       </div>
122
123
124
125       <!-- BEGIN FOOTER -->
126
127
128     </tr>
129   </table>
130   <div id="footer" style="width: 99%;">
131     <a id="hyperLink5" href="/index.jsp?content=privacy.htm">
        Privacy Policy
      </a>
132       |  
133     <a id="hyperLink6" href="/index.jsp?content=security.htm">
        Security Statement
      </a>
134       |  
```

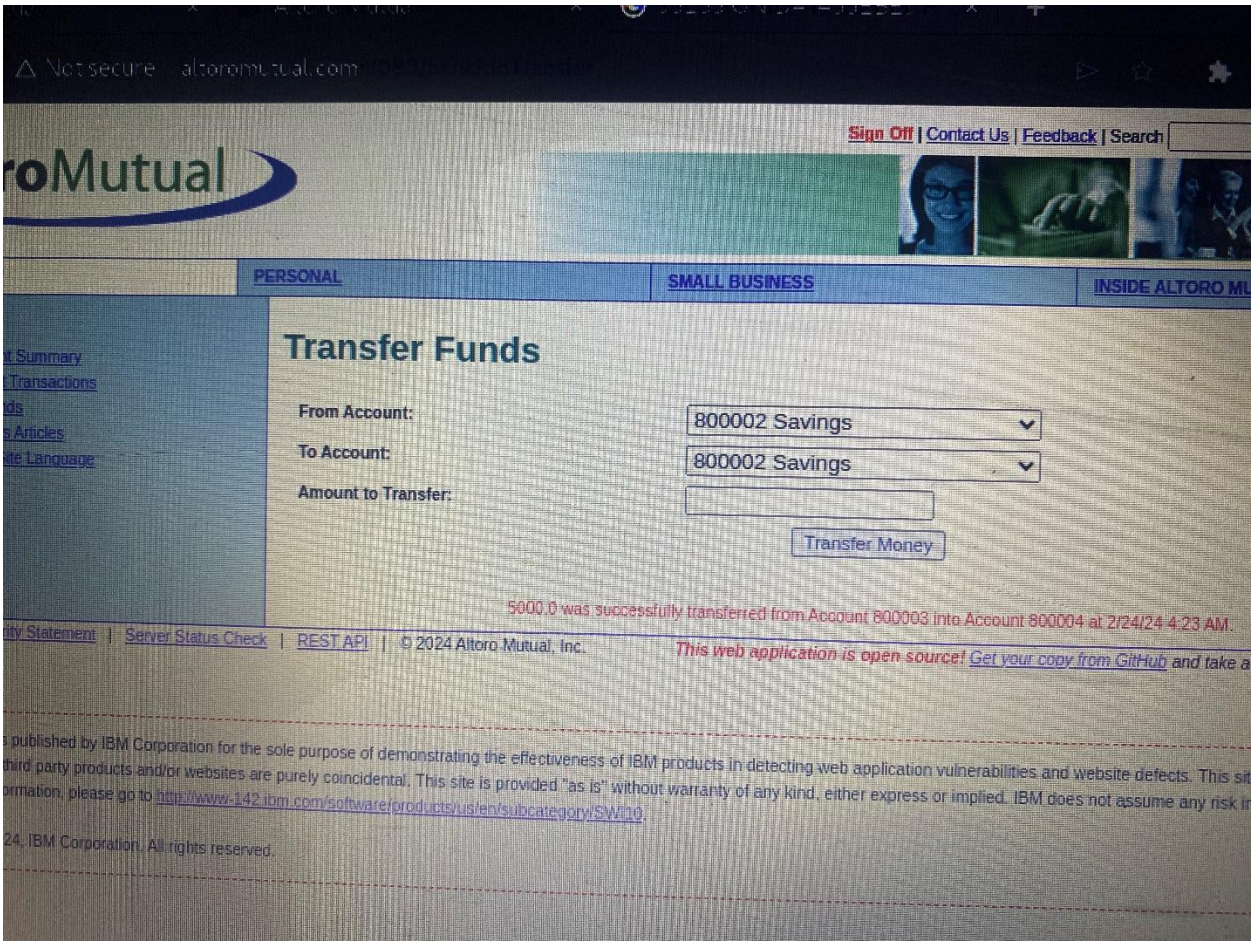
Search 0 highlights

Search 0 highlights

Done

Event log All issues

CONFI



IMPACT:

- Financial loss for the users and the online Banking application
- Fines
- Breach of Confidentiality

MITIGATION:

- Strictly evaluate user input before it is processed
- Make use of complex identifiers, for example adding a column with random strings in the database table and using those strings instead of numeric primary keys.
- Verify user's permission every time an access is attempted.
- Avoid exposing identifiers in URLs and POST bodies if possible. Instead, determine the currently authenticated user from session information. When using multi-step flows, pass identifiers in the session to prevent tampering.

```
// vulnerable, searches all projects
@project = Project.find(params[:id])
// secure, searches projects related to the current user
        @project = @current_user.projects.find(params[:id])
```

- When looking up objects based on primary keys, use datasets that users have access to. Like in Ruby on Rails: example above.

CONFIDENTIAL